IONITY GLOBAL

(Pty) Ltd

Ionity NoteCad

POPIA Compliance Assessment

Voice-first AI workspace, as of 29 October 2026

Personal information · Live checks · The eight conditions · Findings and fixes

DOC-2026-10-NOTECAD-POPIA-01 | Version 1.0 | 29 October 2026
CONFIDENTIAL

www.ionity.today | ai@ionity.today

Index – Table of Contents

Ten sections and one appendix: the summary, what NoteCad holds about people, the live checks, each POPIA condition, data subjects' rights, the findings with fixes by priority, and what Ionity and each owner must still do outside the code.

Section	Topic	Page
1	Summary	–
2	Scope, method and limits	–
3	Who is responsible	–
4	Personal information NoteCad holds	–
5	Live checks on WABAKIPI	–
6	The eight conditions (sections 8-25)	–
7	Data subjects' rights (sections 23-25)	–
8	Special topics	–
9	Findings and fixes, by priority	–
10	Organisational to-do list	–
A	Appendix A - Document control	–

Note: Page numbers are indicative. Actual pagination depends on rendering and may shift slightly between Word versions. Use Word's Navigation Pane (View > Navigation Pane) for live navigation.

1. Summary

This is a technical compliance test of Ionity NoteCad against the Protection of Personal Information Act 4 of 2013 (POPIA). It covers the code as of commit 360e004 (29 October 2026) and the running stack on WABAKIPI. Every finding comes from the source code or from a check run against the live brain. Nothing here is legal advice. Matters the code cannot show, such as registering an Information Officer, are listed in section 10.

Overall: the architecture is favourable to POPIA. Data stays on the owner's PC by default, the cloud speech and model services are off, and role-based access (ADR 0014) limits each person to what they may see. Every change is logged with its author. **Not yet compliant** in four areas: there is no retention limit, deleted information survives in the sync journal and archives, the phone link is plain HTTP on the farm network, and nobody is told what is collected (no privacy notice, no notice to employees or to people heard in recordings).

Area	Result	Most important finding
Accountability (s8)	Partly	audit log and roles in place; no Information Officer, PAIA manual or breach process recorded
Processing limitation (s9-12)	Partly	purpose is clear and minimal; no notice or consent step for employees or for third parties heard on recordings
Purpose specification (s13-14)	Gap	no retention limit: audio, transcripts, sync journal and archives are kept with no end date
Further processing (s15)	Meets	the companion learns only for the owner's own replies, in a store per member
Information quality (s16)	Meets	every note can be corrected, undone, or traced back to its recording
Openness (s17-18)	Gap	no privacy notice in the desktop or phone app
Security safeguards (s19-22)	Partly	strong access control; but plain HTTP on the LAN, unencrypted database and audio, device tokens written to the access log, no breach procedure
Data subject participation (s23-25)	Partly	workspace export and full workspace deletion exist; no per-person access, correction or erasure
Cross-border transfer (s72)	Partly	Claude and Deepgram are off on WABAKIPI; when switched on, note text and audio go to the USA without a recorded basis

2. Scope, method and limits

Item	Detail
Code	github.com/dennisGIonity/Ionity_NoteCad_AI, main at 360e004: brain, companion, desktop app, phone app, Supabase migrations 0001-0008
Stack	WABAKIPI (Windows 11), started with start_notecad.ps1; brain 127.0.0.1:8788, Ollama 127.0.0.1:11434
Method	read every place personal information enters, is stored, leaves, or is deleted; ran live checks (section 5); scored each POPIA condition
Standard	POPIA sections 8-25 (the eight conditions), 26-35 (special and children's information), 55 (Information Officer), 57 (prior authorisation), 69 (direct marketing), 71 (automated decisions), 72 (transfers abroad)
Not covered	contracts and registrations (section 10), the Supabase project settings (none is configured), BitLocker or other disk encryption on WABAKIPI (needs administrator rights), iOS

3. Who is responsible

POPIA puts the duties on the responsible party: whoever decides why and how information is processed. For NoteCad that depends on how it runs:

How NoteCad runs	Responsible party	Ionity's role
On the farm's own PC (today)	the farm business (the owner)	software supplier; not an operator, because Ionity receives no personal information
With an Ionity-run edge node or Supabase project	the farm business	operator (s20-21): needs a written operator agreement with security measures and a duty to report breaches
With Claude or Deepgram switched on	the farm business	Anthropic and Deepgram become operators abroad (s72); Ionity should provide the terms

Ionity should therefore ship a privacy notice template and an operator agreement with NoteCad, so each owner can meet their own duties.

4. Personal information NoteCad holds

Data subjects: the owner; members (managers and employees who join with an invite); people named in notes (workers, contractors, suppliers); anyone audible in a recording.

Information	Where it is kept	How long
Voice recordings	data\brain\audio\<workspace> on the PC (14 files today); phone outbox until uploaded	until the workspace is deleted
Transcripts and note text	brain.db: captures, notes, tasks, alerts (43 captures today)	until deleted
Names and roles of people	person nodes and aliases (e.g. "Thabo, mechanic"); members, seats, invites	until deleted; a revoked member's name stays
Who did what, when	action_log (334 rows), Inbox, refused actions	until the workspace is deleted
Devices	devices: name, token hash, last seen, revoked	until the workspace is deleted
Every change, as a full row copy	sync_changes (11,749 rows), view_changes, sync_conflicts	never pruned, also after deletion
What the companion learned	data\companion: facts (name, role, location, people), style, per-owner LoRA	idle learned facts forgotten after 30 days; stated facts kept
Archives and backups	data\archive: 16 removed-workspace JSON files and 3 full copies of data\ (74 MB, audio included)	no end date
Access log	data\brain\logs\api.out.log (97 KB)	no rotation; holds device tokens (see 5)
Phone copy	IndexedDB / app files: the map the member may see, the outbox, the token	until revoked (then wiped)

Not collected: location (the captures.geo column exists but no app fills it), contacts, identity numbers, health data about people, banking details, children's information. No speaker identification or voiceprint is made, so recordings are not used as biometric information.

5. Live checks on WABAKIPI

Check	Result	Verdict
Which interfaces listen	brain 127.0.0.1:8788, Ollama 127.0.0.1:11434 only	Meets
Request from the LAN address 192.168.0.5	connection refused (not on the network unless started with -Lan)	Meets
Request from this PC with no token	200: this PC is trusted (NC_BRAIN_TRUST_LOOPBACK=1)	Partly
Wrong device token	401	Meets
Revoked device	410 with wipe (Playwright roles.spec, CI)	Meets
Employee reads Financials (owner-only)	never on the map, digest, export, search words or live events (roles.spec)	Meets
Cross-site POST from another website	403	Meets
Cross-site GET	200, but no Access-Control-Allow-Origin, so the browser blocks the read	Meets
Security headers	none (no Content-Security-Policy, X-Frame-Options, nosniff, Cache-Control: no-store)	Gap
Database at rest	plain SQLite (header "SQLite format 3"); audio files unencrypted	Gap
Access log	4 device tokens in full in ?token= on the live-events URL	Gap
Cloud services	ANTHROPIC_API_KEY, NC_BRAIN_DEEPGRAM_KEY, NC_BRAIN_SYNC_TARGET not set in the vault: nothing leaves the PC	Meets
Phone (Android)	allowBackup=false (no cloud backup of app data); usesCleartextTraffic=true, androidScheme http	Partly

6. The eight conditions (sections 8-25)

Condition	Verdict	Evidence	Gap
1 Accountability (s8)	Partly	ADR 0014 roles; every write judged and logged with author and approver	no Information Officer, PAIA manual or compliance framework (s55, Regulation 4)
2 Processing limitation (s9-12)	Partly	collects only what the owner says; no location, contacts or IDs	no notice or consent screen; employees are not told their notes, actions and devices are recorded; third parties heard in recordings are not told
3 Purpose specification (s13-14)	Gap	purpose is stated (blueprint ION-ARC-NOTECAD-2026-001)	no retention period for audio, transcripts, logs, archives or the sync journal (s14 requires one)
4 Further processing (s15)	Meets	the companion learns only to answer the same owner; per-member stores	-
5 Information quality (s16)	Meets	notes can be edited, undone, and checked against the recording	-
6 Openness (s17-18)	Gap	-	no privacy notice in either app, no record of processing (s17)

Condition	Verdict	Evidence	Gap
7 Security safeguards (s19-22)	Partly	roles and views, hashed device tokens, one-time invites, throttled join, CSRF origin check, secrets in a vault outside the repo, revoke wipes phones	plain HTTP on -Lan; database and audio not encrypted; tokens in logs; no security headers; this PC needs no token; no breach procedure (s22); no operator agreements (s20-21)
8 Data subject participation (s23-25)	Partly	workspace export; workspace delete removes audio	no export or erasure for one person; deleted rows survive in sync_changes and archives

7. Data subjects' rights (sections 23-25)

Right	Today	Needed
Access (s23)	the owner can export a whole workspace (JSON)	an export for one person: notes that name them, their recordings, their actions, and what the companion learned about them
Correction (s24)	notes, names and aliases can be edited	-
Deletion (s24)	a whole workspace can be deleted, audio included; companion facts and owners can be deleted	erase one person: their recordings, name, aliases and authored rows (or anonymise them); also from sync_changes, view_changes, sync_conflicts and archives
Objection (s11(3))	-	a way for an employee or third party to object, routed to the owner

8. Special topics

Topic	Finding
Special personal information (s26-33)	not collected by design. Free speech can contain health, religion or union matters about workers; the privacy notice should say not to dictate them, and the per-person erasure covers mistakes
Biometrics	voice is recorded but not used to identify anyone; if speaker identification is added later it becomes biometric (special) information and needs consent
Children (s34-35)	not collected; the notice should say the app is not for children
Prior authorisation (s57)	not needed: no account numbers, credit reporting, or transfer of special information abroad
Direct marketing (s69)	none
Automated decisions (s71)	the router files notes; employee changes are held or refused by fixed rules. Nothing decides about a person with legal effect, and refused changes go to a person. Compliant
Transfers abroad (s72)	off today. When the Claude key is set, note text and map labels go to Anthropic (USA); with the Deepgram key, audio goes to Deepgram (USA). Needs either the data subjects' consent or a binding agreement; switch on only with the notice updated. GitHub CI uses made-up data only
Employees	notes, devices and actions of employees are recorded. Under POPIA and labour law the employer must tell them (written notice, ideally in the employment contract or a policy)

9. Findings and fixes, by priority

#	Priority	Finding	Fix in NoteCad
1	High	No retention limit (s14)	a retention setting per workspace (e.g. audio 90 days, transcripts and logs 1 year); a nightly job that deletes expired audio and prunes sync_changes and view_changes rows every peer has acknowledged
2	High	Deleted information survives (s14, s24)	workspace delete also clears sync_changes, view_changes and sync_conflicts for that workspace; archives get an end date (e.g. 30 days) and are deleted after it
3	High	Device tokens in the access log (s19)	send the live-events token in a header or a short-lived ticket, and redact token= in the log; rotate the 4 logged tokens (all from test runs; revoke them)
4	High	Plain HTTP on the farm network (s19)	TLS for -Lan (a self-signed certificate pinned at pairing), then usesCleartextTraffic=false
5	High	No privacy notice (s18)	a first-run notice on the desktop and on joining a phone: what is recorded, why, how long, who sees it, rights, contact; the owner's details filled in
6	Medium	No per-person access and erasure (s23-24)	"Export person" and "Erase person" in People & seats, across all tables, audio and the companion
7	Medium	Unencrypted database and audio (s19)	require BitLocker on the PC (check it at start-up and warn), or encrypt audio files with a key in the vault
8	Medium	Phone token in plain app storage (s19)	Android Keystore (ADR 0014 decision 19, already planned)
9	Medium	No security headers (s19)	Content-Security-Policy, X-Frame-Options DENY, nosniff, Referrer-Policy, Cache-Control: no-store on API responses
10	Medium	Log files never rotate	rotate weekly, keep 4 weeks
11	Low	This PC needs no token	keep for a single-user PC; the start script should say so and recommend NC_BRAIN_TRUST_LOOPBACK=0 on shared PCs
12	Low	Cloud switches have no privacy gate (s72)	the brain refuses to use Claude or Deepgram until the owner has accepted a transfer notice in the app

10. Organisational to-do list

Who	Action
Ionity Global	register an Information Officer with the Information Regulator; publish a PAIA manual; write a privacy notice template and an operator agreement for NoteCad; a breach procedure (s22: tell the Regulator and the people affected as soon as reasonably possible)
Each farm owner	is the responsible party: give employees written notice; tell people they are being recorded where that applies; decide retention periods; sign the operator agreement if Ionity hosts anything
Before Claude or Deepgram are switched on	check Anthropic's and Deepgram's data terms (retention, training, region); record the s72 basis
Before Supabase is used	pick a region, enable encryption and backups, sign the Supabase data processing addendum

Re-test: after fixes 1-5, run this assessment again; the live checks in section 5 can be repeated against the stack in a few minutes.

Appendix A - Document control

Field	Value
Document	Ionity NoteCad - POPIA compliance assessment
Document ID	DOC-2026-10-NOTECAD-POPIA-01
Version	1.0, 29 October 2026
Prepared by	Dennis Grobler (Wabakipi), with Claude Code | Ionity Global (Pty) Ltd | AEDI
Code assessed	Ionity_NoteCad_AI, main at 360e004
Governance / licence	Policy 986 AED | License AED 900
Rights	(c) 2026 Ionity Global (Pty) Ltd - All rights reserved
Company	IONITY GLOBAL (Pty) Ltd 2026/276325/07 | www.ionity.today | ai@ionity.today
Note	technical assessment, not legal advice; confirm sections 3, 8 and 10 with a POPIA practitioner

Building Tomorrow, Today. | Anything is Possible with God.